

Recovering the Right WebAuthn Account: Intent-Bound Recovery Under Realistic Topologies

Anonymous Submission

Abstract—WebAuthn brings public-key authentication to web deployments, but recovery remains underspecified once users hold multiple authenticators, visible recovery handles, stale credential-lineage state, and several accounts at the same relying party. In these settings, response validity alone does not identify the recovered semantic object. Recovery requires account-specific binding to the intended account and lineage, and provenance-first local admissibility for handles before the client emits the final recovery response.

We introduce **G-CBR**, a topology-aware recovery model with accounts, anchors, epochs, candidate descriptor sets, visible recovery domains, and typed compromise profiles as first-class objects. The model formalizes account-specific recovery authentication (**ASRA**), handle provenance (**HP**), topology unlinkability (**TUL**), and partial-compromise resilience (**PCR**). It yields necessity results showing that same-RP multi-account recovery without account binding violates **ASRA**, and that multi-visible recovery without local provenance discrimination violates **HP**. We then define the intent-bound **iCBR** family, in which the client answers only after a unique candidate is locally admissible under the current account, anchor, epoch, and provenance context. Under context-binding, opening-sound provenance and standard response unforgeability assumptions, honest **iCBR** clients satisfy **ASRA** and **HP** outside target-state compromise.

A frozen semantic campaign evaluates inherited ARKG/CBR and pqCBR-style workflows against the same source of truth, with the current ARKG Internet-Draft used as a standards-track engineering reference. The inherited classical baseline accepts wrong-account recovery in the same-RP world predicted by the model; the repaired classical workflow blocks the observed wrong-account, wrong-anchor, wrong-seed, and stale-descriptor cases while preserving the classical cost envelope. Under multi-domain visibility, inherited post-quantum baselines fail late at the server, while intent-bound variants move the corresponding negative worlds to early local aborts, ordinary acceptances, or explicitly compromise-assisted acceptances. ProVerif and Tamarin encodings, an internal symbolic checker, and an executable HTTP/WebAuthn-like demo corroborate the same distinctions.

I. INTRODUCTION

WebAuthn has made public-key authentication deployable on the Web. Account recovery remains difficult across realistic authenticator lifecycles: users lose devices, replace phones, accumulate multiple passkey-capable authenticators, and operate in ecosystems where several authenticators, recovery handles, and credential lineages may be visible during recovery. In

these settings, recovery protocols must bind the intended semantic object and reject mismatched candidates at the point where the workflow still permits a local decision.

Prior work already exposes this issue. Frymann et al. isolated the cryptographic core of Yubico’s proposal as asynchronous remote key generation (ARKG) and analyzed it as a reusable primitive [1]. Wilson’s thesis and the subsequent pqCBR paper widened the scope from ARKG to credential-based recovery (CBR), exposed a same-RP weakness in the inherited classical design, and proposed a quantum-safe recovery workflow [2], [3]. The current ARKG draft addresses deployment constraints that directly affect recovery behavior: bounded context fields, explicit suite identifiers, and early failure for wrong handles before they surface as opaque server-side errors [4]. Throughout this paper, that Internet-Draft serves as a standards-track engineering reference.

The adversarial surface studied here is descriptor misbinding during recovery candidate presentation. The negative worlds arise when the recovery layer returns a stale descriptor, a sibling-account descriptor, or a foreign-domain handle inside the candidate set presented to an otherwise honest client. The relevant safety boundary is the final recovery response: semantically foreign candidates must be rejected before the client emits it. The model G-CBR generalizes recovery by treating visible authenticator sets, accounts, anchors, epochs, recovery domains, and typed compromise profiles as first-class objects. The intent-bound family iCBR binds recovery to account, anchor, and epoch, and enforces provenance as a client-side admissibility condition before the final recovery response. The evaluation compares inherited and repaired workflows through a frozen empirical campaign, mechanized cross-checks, and an executable local demo.

Realistic WebAuthn recovery is governed by two conditions: *account-specific binding* and *provenance-first local admissibility*. Account-specific binding assigns each recovery attempt to the intended account and gives same-RP multi-account recovery the account-specific authentication property. Provenance-first local admissibility classifies visible handles by origin before server submission and preserves handle provenance in multi-visible recovery. The evaluation reflects these obligations at the trace level. Inherited workflows admit traces ending in wrong-account acceptance or late server-side rejection. Repaired workflows classify the same traces locally: foreign or ambiguous handles reach early local rejection, and provenance-consistent handles reach ordinary acceptance unless the world is explicitly typed as compromise-assisted.

The frozen empirical campaign gives the basis for the

comparison. In the same-RP multi-account world where the model predicts failure, the inherited classical baseline remains broken. The classical repair blocks wrong-account, wrong-anchor, wrong-seed, and stale-descriptor cases while staying within the inherited classical cost envelope. In the post-quantum cases, the campaign’s strongest distinction is the failure locus: inherited PQ baselines fail late at the server under multi-domain visibility, while intent-bound PQ variants move the same negative worlds to early local aborts, ordinary acceptances, or explicitly compromise-assisted acceptances. Necessity-style witnesses, a local HTTP/WebAuthn-like demo, an internal symbolic checker, and external ProVerif and Tamarin encodings corroborate the same distinctions.

Contributions.

- 1) A generalized WebAuthn recovery model with explicit multi-authenticator visibility, credential lineage, and typed compromise.
- 2) Model-level necessary conditions for the target ASRA and HP guarantees, together with a positive composition theorem for iCBR under explicit assumptions on provenance opening and response unforgeability.
- 3) A classical repair that removes the campaign-observed semantic failures while preserving the inherited classical cost envelope.
- 4) An empirical and mechanized comparison showing that the strongest post-quantum distinction in the campaign is the relocation of negative cases from late server failure to early local decision.

II. BACKGROUND AND PROBLEM SETTING

WebAuthn provides a strong public-key authentication interface for the Web, while CTAP governs the client–authenticator channel used by FIDO2 authenticators [5]. Recovery semantics remain open in settings where several authenticators, credential lineages, and visible handles coexist during account recovery. Backup state and synced passkeys change the operational landscape, while dedicated recovery protocols still need to specify how recovery binds to the intended account and how the client handles foreign, stale, or context-inconsistent recovery material.

Two common operational strategies are manual registration of multiple authenticators and reliance on cloud-synced passkey ecosystems. Both are useful operationally, but protocol-level recovery semantics require more than availability of backup credentials. Manual multi-token registration is brittle and difficult to scale across account populations. Synced passkeys mitigate one class of device loss. A dedicated recovery path still needs account-specific recovery rules for wrong-handle selection, stale state, and partial compromise.

ARKG and CBR form the immediate technical background. ARKG extracted a reusable primitive from Yubico’s recovery proposal and showed that authenticator backup admits rigorous cryptographic treatment [1]. Wilson and Stebila widened the scope from ARKG to credential-based recovery, identified a same-RP weakness in the inherited classical design, and

proposed pqCBR as a quantum-safe alternative [2], [3]. The standards track has since sharpened the corresponding engineering constraints. The current ARKG Internet-Draft specifies bounded context fields, explicit suite identifiers, and early discrimination of handles that do not match the current seed or intent before they surface as late protocol failures [4]. In this paper, the draft serves as a standards-track engineering reference.

This work also belongs to the broader formal-analysis line for WebAuthn and FIDO2. Early work modeled the W3C WebAuthn protocol in ProVerif, and later analyses treated FIDO2 as a composition of WebAuthn and CTAP2, refined the model for CTAP 2.1 and WebAuthn 2, and studied privacy, revocation, and post-quantum instantiation [6]–[10]. Across these analyses, the security statement follows the model boundary: what the adversary observes, how authenticators are abstracted, and which lifecycle state is explicit. This paper applies that modeling discipline to recovery by making recovery-specific state explicit: multiple visible authenticators, candidate handles, account contexts, anchors, epochs, and credential lineages.

The problem setting imposes requirements at the model, design, and evaluation levels. The model must expose visible authenticator sets, candidate ambiguity, anchors, epochs, and typed compromise profiles as primary objects. The design must bind recovery to the intended account and enforce provenance-first local rejection for visible handles. The evaluation must report abstract object sizes, ceremony/state cost, failure locus, bounded leakage classes, and typed compromise outcomes under a single source-of-truth policy.

Table I summarizes the main workflows. G-BASE preserves RP-only recovery binding and serves as the inherited classical baseline. PQ-DIL and PQ-LEG preserve explicit RP+account binding but lack provenance-first local rejection. The proposed IC-C-P256 and IC-PQ-* families bind full recovery intent and require deterministic local selection before response emission. The designs differ in object size and in the client’s ability to reject mismatched candidates before emitting the final recovery message.

Figure 1 makes the evaluation problem concrete. The workflow family spans compact classical objects, PQ handles with large response material, and repaired PQ variants marked by a short provenance tag. The frozen campaign evaluates these size profiles together with failure locus and semantic agreement. Under this reading, the classical repair changes behavior within the classical cost envelope, while the repaired PQ line preserves the same provenance-stress universe and moves negative worlds from late server-side failure to early local termination.

III. G-CBR AND THE INTENT-BOUND RECOVERY FAMILY

G-CBR preserves the recovery-core discipline of prior CBR work and interprets that core in a broader operational setting. Realistic recovery includes multiple visible authenticators, several admissible-looking handles, and distinct credential

TABLE I

WORKFLOW OVERVIEW. THE PROPOSED WORKFLOWS DIFFER FROM INHERITED BASELINES IN THE LOCAL ADMISSIBILITY RULE AS MUCH AS IN PRIMITIVE COMPOSITION.

workflow	account-bound	provenance-first	local wrong-seed reject	local stale reject	$rc/rcid/rsp$ (bytes)
G-BASE	no	no	no	no	64/80/64
PQ-DIL	yes	no	no	no	10240/1088/5837
PQ-LEG	yes	no	no	no	512/1088/11489
IC-C-P256	yes	yes	yes	yes	64/80/64
IC-PQ-DIL-T16	yes	yes	yes	yes	10240/1104/5837
IC-PQ-DIL-T32	yes	yes	yes	yes	10240/1120/5837
IC-PQ-LEG-T16	yes	yes	yes	yes	512/1104/11489

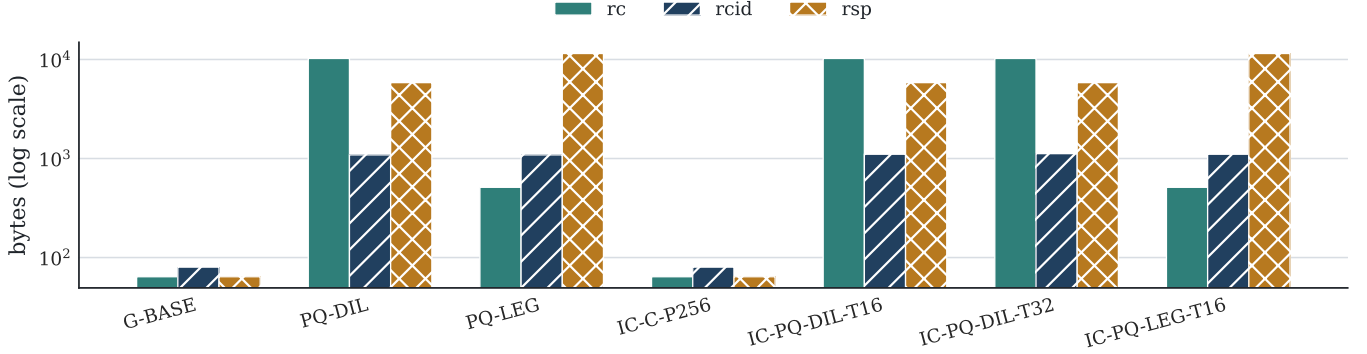


Fig. 1. Abstract object-size landscape across workflows. The artifact records the corresponding size differences; the semantic distinctions track account binding, provenance-first admissibility, and failure locus.

lineages. The generalized model makes visibility and lineage explicit. A user is represented by a topology

$$\text{Topo}(u) = (\mathcal{A}_u, \mathcal{D}_u, E_u^{\text{gen}}, E_u^{\text{own}}, \mathcal{A} \parallel \sqcup_u),$$

where $\mathcal{A}_u$ is the authenticator set, $\mathcal{D}_u$ is the recovery-domain set, E_u^{gen} determines which authenticators may generate descriptors for which domains, E_u^{own} determines which authenticator owns each derivation domain, and $\mathcal{A} \parallel \sqcup_u$ is the user's account set. This structure represents the scenarios exercised later by the artifact: same-RP multi-account recovery, multiple visible handles, shared or separate derivation domains, stale descriptors, and typed compromise profiles.

Each server-side recovery descriptor has the form

$$\delta = (\text{suiteID}, \text{anchorID}, \text{epoch}, rc, rcid, pmeta, status),$$

and each recovery attempt is driven by an intent vector

$$\iota = (rpID, aid, anchorID, epoch, \text{purpose}, \text{suiteID}, \text{policyTag}, ext).$$

The recovery ceremony uses an ordered three-message interface:

$$\begin{aligned} M_1 &= (rpID, aid, \iota), \\ M_2 &= (chal, \Delta, \sigma_S), \\ M_3 &= (rsp, descRef, nc, \sigma_U), \end{aligned}$$

where Δ is the candidate descriptor set returned by the server, $chal$ is the freshness challenge, $descRef$ identifies

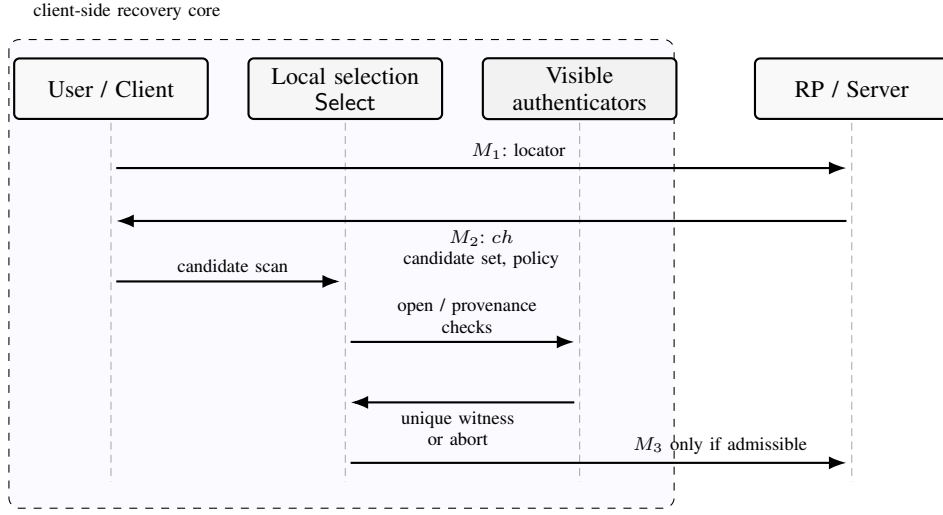
the descriptor answered by the client, and nc is the nonce or challenge binding material carried into the final response. The model allows M_2 to contain more than one candidate. Once the server returns a candidate set, the client solves a local admissibility problem before emitting M_3 . Recovery security depends on cryptographic response validity and on the semantic rule used by the client to select the locally admissible descriptor, if one exists, for the current intent. The model permits user-mediated narrowing of the visible authenticator/domain set, with a final local uniqueness test: M_3 may be emitted only after that narrowing leaves exactly one admissible descriptor-domain witness for the current intent.

Acceptance is evaluated against an agreement vector

$$\text{AV}(\pi) = (rpID, aid, anchorID, epoch, chal, descRef, nc),$$

which records the semantic object recovered by the accepted session. ASRA requires every accepted recovery session to match the intent that initiated it. The property captures agreement on account, lineage, and freshness, in addition to authenticity of the final response. HP covers the remaining recovery-specific obligation: foreign, stale, or context-inconsistent handles are rejected before M_3 is emitted. In this paper, TUL and PCR remain relevant but secondary. TUL is bounded through an operational leakage audit, and PCR is interpreted through a typed compromise matrix.

The negative scenarios considered here place the adversarial effect inside descriptor selection during recovery. Stale de-



G-CBR exposes the candidate set and the local selection step.
iCBR enforces account-, anchor-, and epoch-aware provenance before M_3 leaves the client.

Fig. 2. Recovery-core sequence at the level of G-CBR. The generalization over earlier models is the explicit candidate set in M_2 and the explicit local-selection step before M_3 is emitted.

scriptors, sibling-account descriptors, candidate-set pollution, or foreign-domain handles may enter the set returned to an otherwise honest client. Server behavior in these scenarios is expressed through the candidate set returned to the client; post-recovery account state follows the modeled workflow. The security question is whether the client rejects semantically foreign candidates before M_3 is emitted. The distinction between pre-response local rejection and late server rejection is semantic: once M_3 has been emitted, the client has committed to a descriptor choice and exposed the server as the first provenance oracle for that choice.

The generalized model states all four notions, with distinct evidentiary status for each. ASRA and HP are supported by necessity-style results and direct witnesses in the frozen campaign. TUL and PCR receive narrower operational support from the artifact and associated checks. The paper states full semantic separations for ASRA and HP, and gives TUL and PCR the operational scope established by the implemented workflows.

The model also fixes the adversary surface exercised by the later traces. The server may return candidate sets containing sibling-account, wrong-anchor, stale, or foreign-domain descriptors. The client may observe multiple recovery domains and multiple apparently well-formed handles. The environment carries typed compromise profiles: loss of one authenticator, exposure of an irrelevant derivation domain, exposure of generator-side state, and exposure of the target derivation state. Each profile assigns a distinct security meaning to successful recovery. Target-state exposure yields compromise-assisted success and is classified separately from ordinary resilience. Accordingly, the artifact evaluates K_{target} rows under PCR and keeps them outside the paper’s main authentication claims.

TABLE II
DEPLOYMENT BOUNDARY. G-CBR SPECIFIES RECOVERY-CORE SEMANTICS AND RELATES EACH OBJECT TO DEPLOYMENT ANALOGUES EXPOSED BY RELYING PARTIES, AUTHENTICATORS, USER AGENTS, EXTENSIONS, OR RECOVERY CLIENTS.

G-CBR object	deployment analogue	interpretation in this paper
<i>aid</i>	RP account handle / user handle	intended recovered account
anchorID	credential-lineage identifier	intended credential family
epoch	descriptor lifecycle version	current versus stale state
suiteID	COSE / ARKG suite identifier	explicit suite separation
<i>rcid</i>	recovery handle / key handle	server-returned opening input
local Open / Select	authenticator, user-agent, extension, or recovery client primitive	local provenance check before M_3

The proposed family, iCBR, is built around a local admissibility rule: the client emits M_3 only after establishing that exactly one descriptor is locally admissible for the current intent. The family separates a binding layer from a provenance layer:

$$\mathbb{B} = (\text{BKeyGen}, \text{BindPub}, \text{BindSign}, \text{BVerify}),$$

$$\mathbb{P} = (\text{PKeyGen}, \text{Wrap}, \text{Open}).$$

At registration, the provenance layer creates a binding factor τ and a handle *rcid* under the intent-derived context, and the

TABLE III
SECURITY NOTIONS, THEIR OPERATIONAL MEANING, AND THE EVIDENCE LAYER THAT SUPPORTS THEM IN THIS PAPER.

notion	positive condition	failure mode if omitted or weakened	evidence layer used in this paper
ASRA	accepted recovery agrees on RP, account, lineage, and freshness	same-RP sibling descriptor remains admissible and reaches wrong-account acceptance	necessity result N1 and frozen witness G-BASE/T2/S1
HP	foreign, stale, or context-inconsistent handles are rejected before M_3	wrong-seed or stale candidate survives local selection and fails late or remains ambiguous	necessity results N2/N3, stage taxonomy, and PQ/core traces
TUL	topology information remains within the allowed observation boundary	workflow/topology differences remain distinguishable from public observation classes	operational leakage audit; theorem scope reserved for ASRA and HP
PCR	recovery outcome is typed against partial compromise with a separate compromise-assisted success class	target-state exposure and ordinary resilience collapse into the same success class	typed compromise matrix with explicit quarantine of K_{target}

binding layer turns τ into the public recovery credential rc . At recovery, the client first attempts to recover τ from $(rcid, \iota)$; if this succeeds and reconstructs the expected rc , the binding layer emits a response.

The family induces the deterministic local rule

emit M_3 only when exactly one candidate descriptor has exactly one valid provenance witness under the current intent, anchor, epoch, and visible-domain set.

The rule fixes the workflow’s failure locus and gives operational content to HP. Repaired workflows compute the provenance predicate during local selection, so an invalid candidate terminates before M_3 is emitted. Baselines without this predicate may still reject the same instance after response emission. At that point, the client has committed to a descriptor choice and exposed the protocol to late server-side failure or wrong-account completion. The empirical campaign therefore treats eventual rejection and pre-response rejection as semantically distinct outcomes. If several valid witnesses remain after user-mediated narrowing, the client narrows further or aborts before emitting M_3 ; silent selection among surviving candidates lies outside the admissibility rule.

The artifact instantiates the rule in two branches. IC-C-P256 is the classical branch: compact classical objects, explicit account/anchor/epoch binding, and a wrapper that rejects foreign handles before response emission. IC-PQ-* is the post-quantum branch: the same intent discipline, combined with a blinded PQ signature and a provenance-tagged KEM-style opening path. The classical branch shows that the semantic repair stays within the compact classical envelope. The PQ branch shows that the same semantic discipline moves negative cases from late server failure to early local decision. Together, the two branches turn the model into a design argument: binding and provenance are the mechanisms that separate repaired workflows from inherited baselines.

Defining local admissibility over $(rpID, aid, anchorID, epoch)$ and requiring provenance success before M_3 emission yields five testable obligations. Same-RP sibling descriptors are locally inadmissible. Wrong-anchor

and stale descriptors are rejected as lineage violations. Wrong-seed handles in multi-visible settings terminate before the response leaves the client. The classical branch realizes these semantic gains within the compact classical object family. The PQ branch realizes them by moving negative cases from late server rejection to early local decision. The remainder of the paper proves the obligations necessary at the model level and validates them in the frozen campaign.

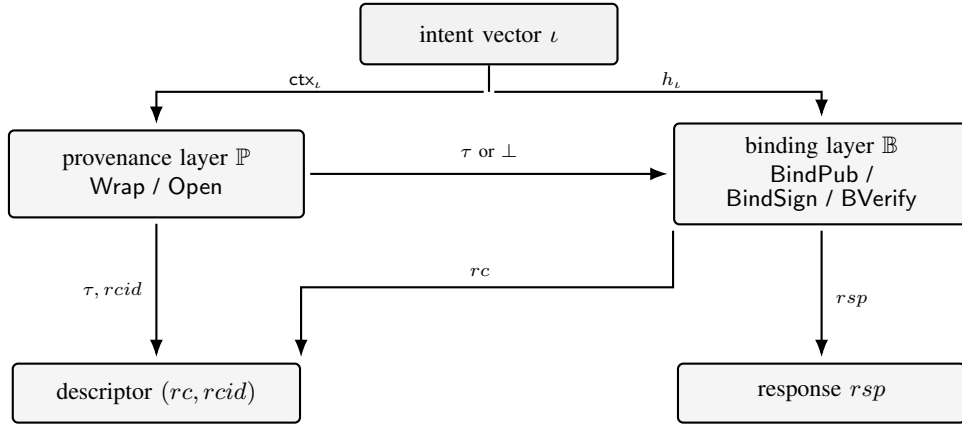
IV. NECESSITY RESULTS

In the G-CBR settings exercised by the evaluation, account identity, provenance, anchor, and epoch appear as separate recovery inputs. The results in this section record model-level minimality witnesses: removing each input from local admissibility admits an executable trace with the corresponding semantic failure.

Proposition 1 (Account binding is necessary for ASRA in same-RP multi-account settings). *Consider a G-CBR world with one RP and two accounts at that RP, and a client-side admissibility predicate that uses $rpID$ and omits aid . Then there exists a candidate set and recovery trace in which a descriptor generated for the second account is accepted during a recovery attempt intended for the first. Therefore ASRA fails.*

Proof. Let δ_1 and δ_2 be active descriptors for the two accounts at the same RP. Suppose the client’s admissibility rule omits aid . During a recovery attempt for the first account, let the server return a candidate set containing only δ_2 . Since the inspected local inputs do not include account identity, δ_2 has the same local account admissibility status as a correct same-RP descriptor. The client emits M_3 for δ_2 , and the server verifies against $rc(\delta_2)$ and accepts.

At acceptance time, the recovered semantic object is tied to the sibling account instead of the requested account. The accepted session fails to agree on the intended account, although the RP-side verification relation succeeds. This violates ASRA, which requires accepted recovery to match the



iCBR splits handle opening from response generation.
The same intent vector drives both layers.

Fig. 3. Internal decomposition of the iCBR family. The provenance layer decides whether a handle belongs to the current intent before the binding layer emits a response.

initiating intent on account and on the rest of the agreement vector. $\square$

Proposition 2 (Provenance-first local integrity is necessary for HP). *Consider a G-CBR instance with multiple visible recovery domains and a client whose local selection rule has no provenance-first discriminator for rejecting foreign handles before M_3 . Then there exists a candidate set containing a foreign handle such that either the client emits M_3 and fails later at the server, or the client has no unique admissible provenance witness. In both cases, HP fails.*

Proof. Let the client observe at least two visible recovery domains, and let the intended descriptor originate from one of them. Suppose the server returns a candidate set containing a foreign but well-formed handle from a different visible domain. The local selection rule provides no provenance-first check that rules out that handle before M_3 is emitted. Two cases remain.

In the first case, the client proceeds with the foreign handle and emits M_3 . Rejection then occurs only as a later server-side failure, so provenance has not been resolved locally before response emission. In the second case, the client cannot derive a unique admissible provenance witness from the candidate set and visible-domain state. Both cases violate the HP discipline that M_3 may be emitted only when exactly one valid provenance witness exists for the current intent. $\square$

Proposition 3 (Anchor and epoch must participate in local intent binding). *If the client's admissibility rule binds recovery to an RP and account while omitting the intended anchor or epoch, and stale or wrong-anchor descriptors can coexist in the candidate set, then there exists a recovery trace in which the client does not reject the wrong descriptor locally.*

Proof. Fix a recovery attempt whose intended lineage is identified by anchor h and epoch $e + 1$. Let the candidate set

contain a descriptor tied either to a different anchor $h' \neq h$ or to the stale epoch e . If the admissibility predicate binds only to the RP and account, neither candidate is excluded by local intent. The client therefore continues with the wrong descriptor or defers rejection to a later semantic checkpoint.

Local rejection of wrong-anchor or stale descriptors depends on anchor and epoch being present in the admissibility rule. The omitted inputs identify credential lineage and lifecycle state. $\square$

The frozen campaign records witness traces for the three propositions: G-BASE/T2/S1 for same-RP wrong-account recovery, PQ-DIL/T5/S5 for the wrong-seed late-failure case, and the stale/wrong-anchor pair for anchor and epoch.

Theorem 4 (Intent-bound provenance and binding suffice for ASRA and HP). *Assume that the provenance layer is context-binding and opening-sound with respect to ctx_ι , that the binding layer is unforgeable for records containing $(chal, nc, \iota)$, that local admissibility is evaluated after any user-mediated narrowing of the visible set, and that the compromise profile lies outside K_{target} . Then honest-client iCBR executions satisfy ASRA and HP in the G-CBR model.*

Proof. If an honest iCBR client emits M_3 , then exactly one admissible provenance witness remains after any user-mediated narrowing of the visible set. Opening soundness implies that this witness arises from a handle created under the same intent-derived context. Handles from any other context fail opening. Binding-layer soundness then implies that a valid response can be produced only for the credential reconstructed from that witness and bound to $(chal, nc, \iota)$. Hence an accepting session agrees with the initiating intent on account, lineage, and freshness, giving ASRA.

The same reasoning gives HP. Foreign, stale, or context-inconsistent handles either fail opening, fail reconstruction, or leave no unique admissible witness, in which case M_3 is not

emitted. Provenance is established before response emission. The exclusion of K_{target} keeps compromise-assisted successes outside the theorem’s scope. $\square$

Corollary 1 (The classical repair preserves the classical cost envelope). *Within the artifact’s abstract-object and ceremony/state layers, the classical repair IC-C-P256 preserves the compact classical cost envelope of G-BASE while removing the campaign-observed wrong-account, wrong-anchor, wrong-seed, and stale-descriptor behaviors.*

Evidence sketch. In the frozen core campaign, both workflows retain $rc/rcid/rsp = 64/80/64$ at the abstract recovery-object layer. Account, anchor, epoch, suite, and policy identifiers live in the intent/context layer rather than appearing as new public-key objects. At the separate ceremony/state layer, the deltas remain negligible, while the repaired workflow blocks the negative worlds admitted by the baseline. The repair preserves the classical object family measured by the campaign: the semantic delta is large and the cost delta is small.

Propositions 1 to 3 identify the inherited counterexample classes that remain reachable when the relevant inputs are absent from local admissibility. Theorem 4 supplies the positive closure for the proposed family under explicit assumptions on opening soundness and response generation. Corollary 1 shows that the classical repair removes those classes while staying within the compact classical envelope occupied by the baseline. The resulting evidence links model-level necessity, positive sufficiency, semantic repair, and practical cost preservation.

V. FROZEN ARTIFACT AND EMPIRICAL EVALUATION

The empirical evaluation rests on a frozen campaign with three slices: a core slice for baseline fidelity and the classical repair, a PQ/provenance slice for failure-locus analysis under multi-domain visibility, and a leakage slice for bounded observation-class audits. The source-of-truth policy is fixed throughout: inherited baselines use inherited semantics, repaired workflows use their specified local-admissibility rules, and reported results come from frozen runs, traces, and tables. These readouts cover abstract object sizes, ceremony and server-state cost, failure locus, bounded observation classes, and typed compromise outcomes. Trial counts record regression coverage over regenerated semantic worlds.

The readouts are grouped by evidentiary role. The core summary establishes baseline fidelity and the coverage of the classical repair. The cost table and object-size figure place that repair within the inherited classical envelope. The failure-locus and PQ timing figures track the relocation of negative cases to local rejection in repaired workflows. The leakage and compromise layers support the bounded TUL and PCR claims. Together, the readouts compare workflows across object size, state, and semantic outcome.

A. The inherited classical baseline fails in the predicted same-RP case

Table VII records the baseline-fidelity witness. In the frozen core campaign, G-BASE accepts same-RP wrong-account recovery in all 25/25 T2/S1 trials, giving the empirical witness for Proposition 1. The preserved trace has the failure pattern ruled out by ASRA: recovery is initiated for one account, the RP returns a sibling same-RP descriptor, RP-only admissibility permits the client to emit M_3 , and the server completes recovery for the wrong account.

This baseline case anchors the repaired-workflow comparison. Each repair is measured against the concrete account-binding failure isolated by Proposition 1.

B. The classical repair removes the campaign-observed semantic failures within the classical envelope

The same campaign shows that IC-C-P256 blocks the four negative cases motivating the classical repair: wrong-account substitution, wrong-anchor substitution, wrong-seed handles, and stale descriptors. Each world exercises a distinct admissibility input. T2/S1 tests account identity. T2/S2 tests anchoring to the intended credential family. T5/S5 tests local exclusion of foreign handles. T6/S7 tests epoch-sensitive rejection of stale descriptors. Together, these cases cover the account, anchor, provenance, and epoch obligations introduced by the generalized model.

The cost result in Table VIII and Figure 4 supports Corollary 1. At the abstract recovery-object layer, both workflows remain at $rc/rcid/rsp = 64/80/64$. At the separate ceremony/state layer, the deltas are limited to -1 peak byte, -1 total byte, -3 server-state bytes, and no additional round. The accounting separates public-key recovery objects from intent/context fields: account, anchor, epoch, suite, and policy identifiers live in the intent/context layer, which is counted separately at higher serialization and ceremony layers. The repair is therefore cost-neutral at the recovery-object layer while still changing the local admissibility semantics.

C. Provenance-first local rejection is operationally visible

The repaired family changes both negative-case outcomes and their failure locus. In repaired classical and PQ workflows, wrong-seed and stale cases terminate before successful server completion; in the critical wrong-seed world, they terminate before M_3 leaves the client. This gives operational content to HP: handle provenance is enforced during local selection, before the client commits to a descriptor choice.

The auxiliary S5-post-open-rc-mismatch trace refines this local-failure account. The artifact separates open-abort from post-open-local-reject. In the first case, no valid provenance witness opens under the current intent. In the second, opening succeeds, but the recovered witness fails to reconstruct the required binding relation. Both outcomes are local rejections, occurring at distinct semantic checkpoints in the handle-provenance test.

TABLE IV
FROZEN CAMPAIGN STRUCTURE.

run	workflows	topologies	scenarios	use in the paper
core	G-BASE, IC-C-P256, IC-PQ-DIL-T16	T1, T2, T5, T6	S0, S1, S2, S3, S4, S5, S7, S8, S9-63/64/65	baseline fidelity, classical repair, wrong-seed and stale rejection, boundary control
PQ/provenance	PQ-DIL, PQ-LEG, IC-PQ-DIL-T16, IC-PQ-LEG-T16, IC-PQ-DIL-T32	T3, T5, T7, T8	S5, S5-post-open-rc-mismatch, S10-S14	late failure versus early local decision, compromise typing, tag sensitivity
leakage	G-BASE, PQ-DIL, IC-C-P256, IC-PQ-DIL-T16	T1, T2, T7, T8	S15, S16	bounded observation-class audit only

TABLE V
BASELINE POLICY. THE BASELINES PRESERVE PUBLISHED RECOVERY BEHAVIOR WHILE THE REPAIRS ENFORCE LOCAL ADMISSIBILITY.

prior design	published binding surface	artifact baseline behavior	discipline reserved for repaired workflows and role in the evaluation
G-BASE	RP-level binding	recovery preserves RP-only admissibility and same-RP sibling-account vulnerability	explicit account/anchor/epoch admissibility is reserved for repaired workflows; this baseline witnesses the inherited same-RP misbinding world
PQ-DIL	RP+account binding	preserves inherited PQ account binding and late server-side provenance failure	provenance-first local admissibility is reserved for repaired workflows; this baseline preserves the inherited response-before-provenance discipline
PQ-LEG	RP+account binding	same semantic policy as PQ-DIL under the alternate PQ signature family	same discipline boundary as PQ-DIL; the evaluated scope is the inherited response-before-provenance baseline

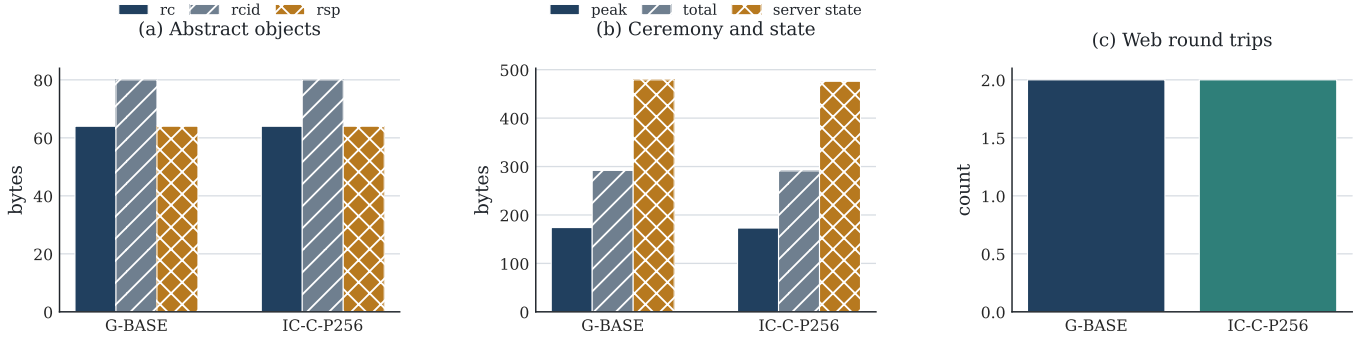


Fig. 4. Classical cost envelope. The classical repair removes the observed semantic failures while staying inside the inherited classical object and ceremony/state envelope.

D. PQ evaluation under multi-domain visibility

The PQ branch is governed by a failure-locus split. The denominator is the fixed campaign surface for each workflow: 20 semantic worlds, each replayed over 25 regenerated trials, for a total of 500 rows. In that setting, PQ-DIL and PQ-LEG each exhibit late failure in 425/500 cases, no early local aborts, 50/500 ordinary acceptances, and 25/500 compromise-assisted acceptances. By contrast, IC-PQ-DIL-T16, IC-PQ-LEG-T16, and IC-PQ-DIL-T32 exhibit zero late failures, 125/500 early local aborts, 275/500 ordinary accep-

tances, and 100/500 compromise-assisted acceptances. The campaign isolates the stage at which rejection occurs while keeping K_{target} outcomes separate from positive resilience evidence.

The 500-case denominator fixes the provenance-stress surface for each inherited PQ workflow: wrong-seed handles, post-open mismatch, and typed compromise cases under multiple visible domains. The repaired PQ line is evaluated over the same surface, so the changed outcome split measures the effect of provenance-first admissibility. Inherited PQ workflows defer

TABLE VI
SCENARIO SEMANTICS.

scenario	semantic perturbation	repaired outcome	property exercised
S1	same-RP sibling-account descriptor returned for the requested account	open-abort	ASRA / account binding
S2	wrong-anchor descriptor from a different credential lineage	open-abort	lineage binding
S5	wrong-seed or foreign-domain handle under multi-visible domains	open-abort	HP / provenance-first admissibility
S5-post-open-rc-mismatch	opening succeeds but binding reconstruction fails locally	post-open-local-reject	post-opening local integrity
S7	stale descriptor for an older epoch	open-abort	epoch-aware admissibility
S9-63/64/65	context-length boundary controls	accept	boundary sanity control
S10-S14	typed compromise and provenance-stress worlds spanning none, K_{loss} , K_{xdom} , K_{pub} , and K_{target}	ordinary accept, compromise-assisted accept, or local abort	bounded PCR interpretation

TABLE VII
CORE CAMPAIGN SUMMARY.

workflow	topology	scenario	interpretation	accept rate	wrong-account rate	provenance stage
G-BASE	T2	S1	same-RP wrong-account baseline witness	25/25	25/25	accept
G-BASE	T2	S2	wrong-anchor world remains admissible in inherited classical baseline	25/25	0/25	accept
G-BASE	T5	S5	wrong-seed handle fails only after response emission	0/25	0/25	server-reject
G-BASE	T6	S7	stale descriptor remains admissible in inherited classical baseline	25/25	0/25	accept
IC-C-P256	T2	S1	classical repair blocks wrong-account recovery	0/25	0/25	open-abort
IC-C-P256	T2	S2	classical repair blocks wrong-anchor substitution	0/25	0/25	open-abort
IC-C-P256	T5	S5	wrong-seed handle rejected locally	0/25	0/25	open-abort
IC-C-P256	T6	S7	stale descriptor rejected locally	0/25	0/25	open-abort
IC-PQ-DIL-T16	T5	S5	PQ wrong-seed handle rejected locally	0/25	0/25	open-abort
IC-PQ-DIL-T16	T6	S7	PQ stale descriptor rejected locally	0/25	0/25	open-abort
IC-PQ-DIL-T16	T1	S9-65	boundary control preserves ordinary acceptance	25/25	0/25	accept

TABLE VIII
CLASSICAL REPAIR DELTA.

metric	G-BASE	IC-C-P256	Δ
rc	64	64	0
$rcid$	80	80	0
rsp	64	64	0
peak bytes	174	173	-1
total bytes	292	291	-1
server state bytes	479	476	-3
rounds	2	2	0

provenance resolution to the server and fail late. Repaired PQ workflows apply the provenance rule locally, moving the corresponding negative cases to early client-side termination. Emitting M_3 for a foreign descriptor commits the client to that descriptor choice before provenance is settled. HP is a pre-response safety property.

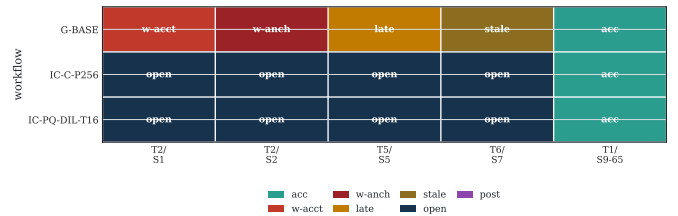


Fig. 5. Failure-locus shift in the core campaign. Inherited baselines reach acceptance or late server-side rejection in scenarios where repaired workflows abort locally.

E. Sensitivity and leakage bound the auxiliary claims

The 16-byte/32-byte provenance-tag study has the expected cost profile: the longer tag increases handle and serialized size, and the early-abort/accept split remains stable over the sensitivity universe exercised here. The leakage audit records that PQ-DIL exposes more public observation classes than

TABLE IX
PQ TIMING SPLIT WITH COMPROMISE-SEPARATED ACCEPTANCE.

workflow family	late	early abort	ordinary acc.	comp.-assisted acc.
inherited PQ	425/500	0/500	50/500	25/500
repaired PQ	0/500	125/500	275/500	100/500

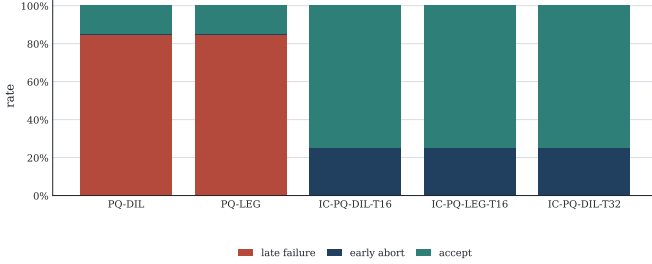


Fig. 6. PQ failure timing under multi-domain visibility. The inherited PQ baselines accumulate late server-side failures; the intent-bound variants move the same negative cases into early local aborts, ordinary acceptance, or explicitly compromise-assisted acceptance.

the classical and repaired protagonists. These readouts bound the auxiliary claims. The tag study checks stability of the timing result under the tested tag-length variation. The leakage and compromise layers report observation classes and typed compromise outcomes as operational evidence for the TUL and PCR discussion.

Table X reports the cost profile across the workflow families. The campaign compares semantic repairs across distinct object regimes. The classical repair changes recovery semantics while remaining within the inherited classical object family. The PQ repairs preserve the inherited signature/KEM branch, add the expected short provenance tag, and obtain their main gain through failure-locus relocation. The paper therefore reports object size, ceremony traffic, server state, and failure locus together.

VI. MECHANIZED CORROBORATION AND EXECUTABLE DEMO

The artifact adds an internal symbolic checker, separate ProVerif and Tamarin encodings, and a local HTTP/WebAuthn-like demo bundle. These components serve as corroborating abstraction checks: the same attack and repair distinctions are evaluated across executable, symbolic, and protocol-level representations.

The verification package distributes corroboration across three abstraction levels. The internal checker executes the workflow-sensitive semantics, preserving distinctions among wrong-account acceptance, late server failure, *open-abort*, and *post-open-local-reject*. ProVerif checks the shared recovery core through correspondence properties for honest acceptance, same-account matching, and replay rejection. Tamarin verifies the witness structure used by the model-level claims: wrong-account acceptance for G-BASE, late-

failure traces for inherited PQ baselines, and local-rejection lemmas for repaired classical and PQ variants.

Figure 7 and Table XI summarize this distribution of evidence. Inherited workflows satisfy honest acceptance and replay rejection in settings that do not stress account binding or provenance. The separation appears in the negative obligations: G-BASE admits the wrong-account witness, inherited PQ baselines admit wrong-seed and stale late-failure witnesses, and repaired classical/PQ workflows verify the local-rejection obligations.

The local HTTP/WebAuthn-like demo exposes the same attack and repair pattern through live endpoints. In *same-rp-wrong-account*, G-BASE reaches */recover/complete* and accepts the wrong account. In *same-rp-repair*, IC-C-P256 aborts locally on the same endpoint family. The PQ demo cases separate late server rejection, *open-abort*, and *post-open-local-reject*. Across these cases, the server serves the wrong descriptor, the inherited line answers for it, and the repaired line halts before the final response leaves the client.

VII. DISCUSSION AND LIMITATIONS

Same-RP multi-account recovery makes account binding a protocol obligation. In this setting, the client must resolve handle provenance before emitting M_3 : once a wrong handle is carried into M_3 , the workflow has already crossed the boundary governed by HP, regardless of whether the server subsequently rejects the attempt. The anchor and epoch therefore cannot be treated as ancillary metadata. They are semantic recovery inputs, because they determine whether the descriptor presented to the client belongs to the intended credential lineage.

This is why the evaluation records more than response size and a binary success/failure outcome. Those observables are insufficient to distinguish a safe local rejection from a late server-side rejection, or either of these from a wrong-account acceptance. The campaign instead records agreement with the intended account and lineage, the locus of failure, and the resulting outcome class. Account binding and handle provenance are properties of the recovery workflow as a whole, not of a single response object considered in isolation, which makes the separation necessary.

The provenance-stress campaign exposes this distinction most clearly in the PQ branch. The timing split measures where failure occurs: locally, before M_3 emission, or later, after the protocol has already relied on a semantically wrong descriptor. The leakage audit provides the corresponding operational evidence for TUL. The typed compromise matrix further prevents compromise-dependent recoveries from being counted as resilience: in particular, K_{target} successes are classified as compromise-assisted and are excluded from positive resilience evidence.

The campaign is built around the recovery conditions under which account binding and provenance become protocol-visible: multiple visible domains, multiple relying parties,

TABLE X
REPRESENTATIVE WORKFLOW COST SUMMARY ACROSS CLASSICAL AND PQ PROTAGONISTS.

workflow	<i>rc</i>	<i>rcid</i>	<i>rsp</i>	peak bytes	total bytes	server-state bytes	rounds
G-BASE	64	80	64	174	292	479	2
IC-C-P256	64	80	64	173	291	476	2
PQ-DIL	10240	1088	5837	5886	7081	11673	2
PQ-LEG	512	1088	11489	11538	12733	1945	2
IC-PQ-DIL-T16	10240	1104	5837	5886	7085	11675	2
IC-PQ-DIL-T32	10240	1120	5837	5886	7101	11691	2
IC-PQ-LEG-T16	512	1104	11489	11538	12737	1961	2

workflow	G-BASE	pass T:gbase_account_binding	pass T:gbase_account_binding	cex T:gbase_account_binding	cex T:gbase_account_binding	cex I	cex I
	IC-C-P256	pass T:ic_classical_repair	pass T:ic_classical_repair	pass T:ic_classical_repair	pass T:ic_classical_repair	pass T:ic_classical_repair	pass T:ic_classical_repair
	PQ-DIL	pass T:pq_baseline_provenance	pass T:pq_baseline_provenance	pass I	pass I	cex T:pq_baseline_provenance	cex T:pq_baseline_provenance
	IC-PQ-DIL-T16	pass T:ic_pq_repair	pass T:ic_pq_repair	pass I	pass I	pass T:ic_pq_repair	pass T:ic_pq_repair
		honest acceptance	replay rejection	same account matching	wrong account injection	wrong seed local rejection	stale descriptor rejection
		pass	pass	counterexample	counterexample	cross-check target	cross-check target

Fig. 7. Best available corroboration per workflow/property cell.

TABLE XI
CONDENSED CORROBORATION SUMMARY.

layer	scope	result pattern
internal checker	all workflows	G-BASE: 3 pass, 3 counterexample; PQ-DIL/PQ-LEG: 4 pass, 2 counterexample; repaired workflows: 6 pass, 0 counterexample
ProVerif	shared recovery core	honest acceptance, same-account matching, and replay rejection for the abstract core skeleton
Tamarin	baseline and repaired witness models	wrong-account witness for G-BASE; late-failure witnesses for inherited PQ; local-rejection lemmas for repaired classical and PQ lines

shared and separate derivation domains, and typed compromise. Threshold recovery, social recovery, browser-level UI orchestration, and full CTAP integration are not modeled here, since each would add further trust assumptions, interaction paths, and implementation mechanisms on top of the recovery question isolated by the artifact. The same qualification applies to the post-quantum construction, which is hybrid only in the

artifact instances where that status is explicitly reported. The model should therefore be read as a recovery-core account of the values that must be bound, checked, and audited before a recovery attempt is allowed to become protocol-visible: account identity, lineage, descriptor provenance, suite identity, and local admissibility.

The classical branch reinforces this interpretation. IC-C-P256 shows that the generalized recovery model is not an effect of post-quantum migration, nor a consequence of larger PQ descriptors or new cryptographic suites: the same account-binding and provenance discipline that prevents a PQ workflow from carrying a wrong descriptor into M_3 also produces a compact classical repair whose measured object sizes, ceremony cost, and round complexity remain within the inherited classical envelope. The PQ branch applies the same discipline to multi-domain visibility settings, where the semantic difference between local rejection, late server rejection, and compromise-assisted acceptance appears in the failure locus.

The standards-facing lesson is that recovery specifications based only on RP-level binding leave account identity, lineage, and local handle provenance to implementation-specific behavior. That latitude admits the same-RP and multi-visible worlds isolated here. Specifications that surface account, anchor, epoch, suite identity, and local admissibility as explicit recovery inputs make those settings testable at the protocol level. In deployment terms, the paper gives a recovery-core semantics for browsers, authenticators, extensions, or dedicated recovery

clients, with local interfaces supplied by the relevant recovery component. The contribution identifies the recovery inputs needed for audit, interoperability, and meaningful conformance testing.

VIII. CONCLUSION

WebAuthn account recovery now operates across lifecycles with multiple accounts, authenticators, visible handles, and credential lineages. In this setting, correctness is governed by two recovery-specific obligations: account-specific binding and provenance-first local admissibility. Account binding ties each recovery attempt to the intended account and credential lineage. Provenance-first local admissibility requires the client to resolve visible handles before emitting M_3 . G-CBR makes these inputs explicit, and iCBR instantiates them through intent binding and local provenance selection.

The frozen campaign separates the resulting effects across the classical and post-quantum branches. In the classical branch, G-BASE accepts the same-RP wrong-account case predicted by the model, while IC-C-P256 blocks the campaign-observed wrong-account, wrong-anchor, wrong-seed, and stale-descriptor cases within the inherited classical cost envelope. In the post-quantum branch, inherited workflows accumulate late server-side failures under multi-domain visibility, while intent-bound variants classify the same provenance-stress cases as early local aborts, ordinary acceptances, or explicitly compromise-assisted acceptances. The mechanized checks and local executable demo preserve the same distinctions across symbolic and protocol-level representations.

These results give WebAuthn recovery a semantic account in which account identity, lineage, handle provenance, and failure locus are measured directly. Response validity and object size remain necessary engineering signals, but the recovered semantic object determines whether a recovery workflow preserves the intended account and credential lineage. For standards and conformance testing, the implication is concrete: account identity, anchor, epoch, suite identity, and local admissibility should be explicit recovery inputs. Making those inputs visible gives implementations an auditable recovery semantics and gives test suites the negative worlds needed to distinguish inherited baselines from intent-bound recovery designs.

ETHICS CONSIDERATIONS

This work does not involve human subjects, live users, or measurements against third-party production services. The executable demo operates entirely over a local HTTP/WebAuthn-like laboratory stack, and the preserved weaknesses are reconstructed from inherited recovery designs and synthetic traces.

REFERENCES

[1] N. Frymann, D. Gardham, F. Kiefer, E. Lundberg, M. Manulis, and D. Nilsson, “Asynchronous remote key generation: An analysis of yubico’s proposal for w3c webauthn,” in *Proceedings of the 2020 ACM SIGSAC Conference on Computer and Communications Security*, ser. CCS ’20. New York, NY, USA: Association for Computing Machinery, 2020, p. 939–954. [Online]. Available: <https://doi.org/10.1145/3372297.3417292>

[2] S. M. Wilson, “Post-quantum account recovery for password-less authentication,” Master’s thesis, University of Waterloo, Apr. 2023. [Online]. Available: <https://uwspace.uwaterloo.ca/items/d1f73f71-e3b2-438c-b261-11632becdbb2>

[3] D. Stebila and S. Wilson, “Quantum-safe account recovery for webauthn,” in *Proceedings of the 19th ACM Asia Conference on Computer and Communications Security*, ser. ASIA CCS ’24. New York, NY, USA: Association for Computing Machinery, 2024, p. 1814–1830. [Online]. Available: <https://doi.org/10.1145/3634737.3661138>

[4] E. Lundberg and J. Bradley, “The Asynchronous Remote Key Generation (ARKG) algorithm,” Internet Engineering Task Force, Internet-Draft draft-bradleylundberg-cfrg-arkg-10, Feb. 2026, work in Progress. [Online]. Available: <https://datatracker.ietf.org/doc/draft-bradleylundberg-cfrg-arkg/10/>

[5] Web Authentication Working Group, “Web Authentication: An API for accessing Public Key Credentials Level 3,” World Wide Web Consortium, W3C Candidate Recommendation Snapshot, Jan. 2026. [Online]. Available: <https://www.w3.org/TR/2026/CR-webauthn-3-20260113/>

[6] I. B. Guirat and H. Halpin, “Formal verification of the w3c web authentication protocol,” in *Proceedings of the 5th Annual Symposium and Bootcamp on Hot Topics in the Science of Security*, ser. HoTSoS ’18. New York, NY, USA: Association for Computing Machinery, 2018. [Online]. Available: <https://doi.org/10.1145/3190619.3190640>

[7] M. Barbosa, A. Boldyreva, S. Chen, and B. Warinschi, “Provable security analysis of FIDO2,” in *Advances in Cryptology – CRYPTO 2021*, ser. Lecture Notes in Computer Science, T. Malkin and C. Peikert, Eds., vol. 12827. Springer, Cham, 2021, pp. 125–156. [Online]. Available: https://doi.org/10.1007/978-3-030-84252-9_5

[8] J. Guan, H. Li, H. Ye, and Z. Zhao, “A formal analysis of the FIDO2 protocols,” in *Computer Security – ESORICS 2022*, ser. Lecture Notes in Computer Science, V. Atluri, R. D. Pietro, C. D. Jensen, and W. Meng, Eds., vol. 13556. Springer, Cham, 2022, pp. 3–21. [Online]. Available: https://doi.org/10.1007/978-3-031-17143-7_1

[9] N. Bindel, C. Cremers, and M. Zhao, “Fido2, ctap 2.1, and webauthn 2: Provable security and post-quantum instantiation,” in *2023 IEEE Symposium on Security and Privacy (SP)*, 2023, pp. 1471–1490.

[10] L. Hanzlik, J. Loss, and B. Wagner, “Token meets wallet: Formalizing privacy and revocation for fido2,” in *2023 IEEE Symposium on Security and Privacy (SP)*, 2023, pp. 1491–1508.

APPENDIX A SUPPLEMENTARY FIGURES

This appendix collects three supporting figures: the tag-sensitivity split inside the repaired PQ family, the leakage-surface audit, and the typed compromise matrix.

A. Executable Demo Views

The next two figures summarize the local HTTP/WebAuthn-like demo. The first figure shows the endpoint-level consequences of the attack/repair pairs discussed in the main text. The second figure records the case-to-endpoint-to-outcome alignment across the five preserved demo cases.

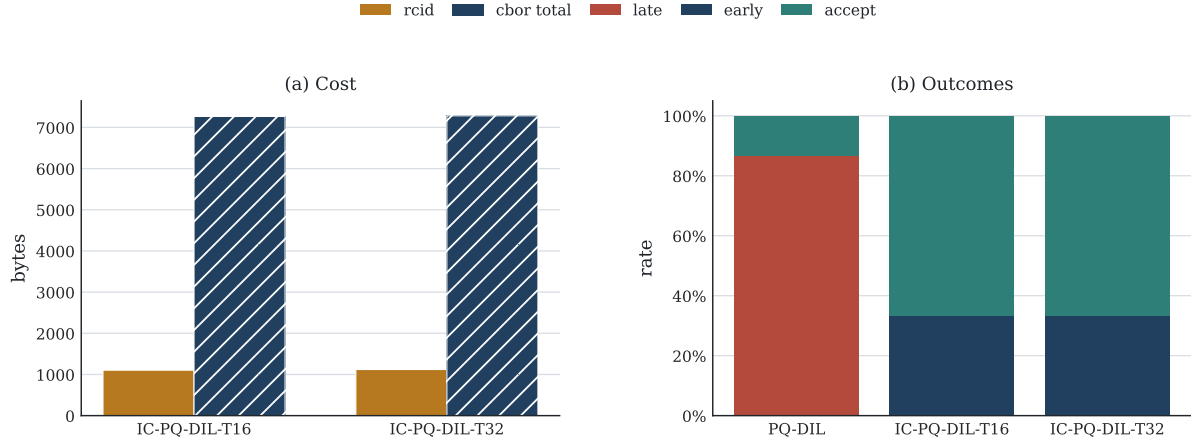


Fig. 8. Tag sensitivity in the supported design sub-universe. IC-PQ-DIL-T16 and IC-PQ-DIL-T32 exhibit the same observed late-failure, early-abort, and acceptance split in the supported sensitivity cases, while the longer tag pays the expected cost in handle and serialization size.

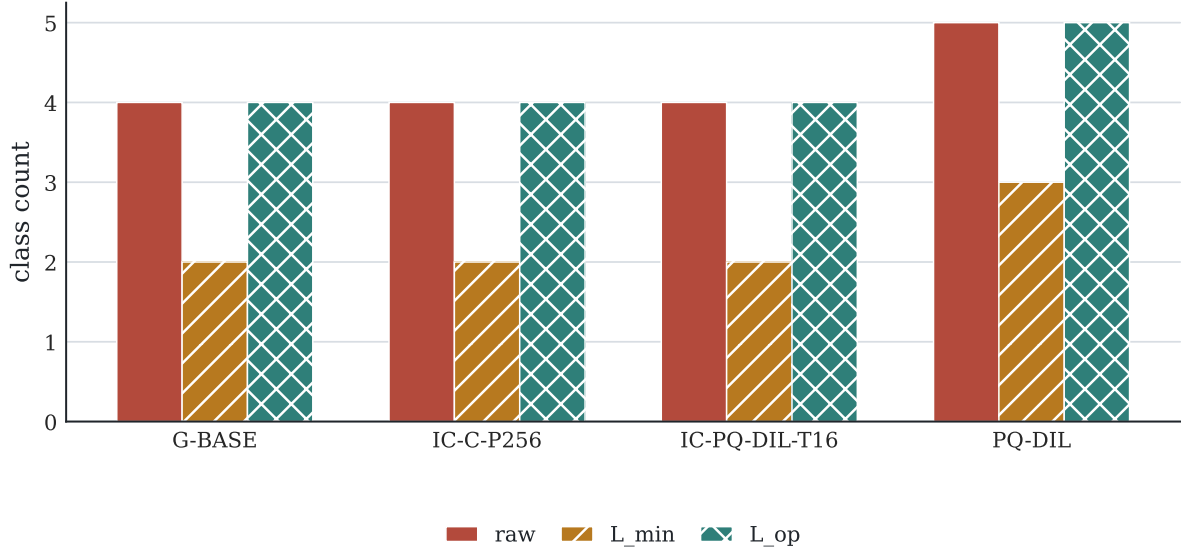


Fig. 9. Leakage-surface audit. PQ-DIL exposes a larger public observation surface than the classical and repaired protagonists under the artifact's observation model.

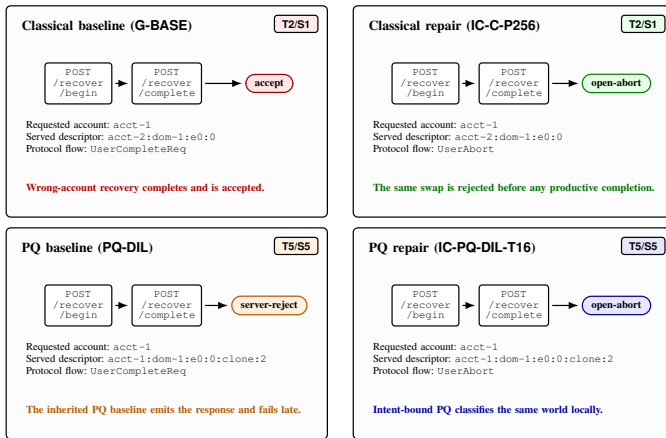


Fig. 11. Endpoint-level consequences in the local demo. The classical pair captures the same-RP wrong-account weakness and repair; the PQ pair captures the shift from late failure at /recover/complete to local abort before an acceptable response is produced.

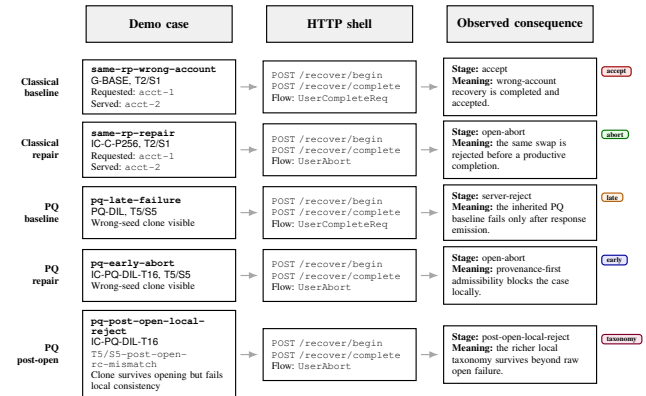


Fig. 12. HTTP/WebAuthn-like demo traceability. The figure maps each replayed recovery world to the shared endpoint shell and records the outcome stage that separates inherited from repaired workflows.

		ordinary accept				compromise-assisted accept				late / reject						
workflow	PQ-DIL	K_loss acc	K_loss late	K_pub acc	K_target acc	K_loss late	K_pub late	K_target late	K_loss late	K_xdom late	K_pub late	K_target late	K_loss late	K_xdom late	K_pub late	K_target late
	PQ-LEG	K_loss acc	K_loss late	K_pub acc	K_target acc	K_loss late	K_pub late	K_target late	K_loss late	K_xdom late	K_pub late	K_target late	K_loss late	K_xdom late	K_pub late	K_target late
	IC-PQ-DIL-T16	K_loss acc	K_loss acc	K_pub acc	K_target acc	K_loss acc	K_pub acc	K_target acc	K_loss acc	K_xdom acc	K_pub acc	K_target acc	K_loss acc	K_xdom acc	K_pub acc	K_target acc
	IC-PQ-LEG-T16	K_loss acc	K_loss acc	K_pub acc	K_target acc	K_loss acc	K_pub acc	K_target acc	K_loss acc	K_xdom acc	K_pub acc	K_target acc	K_loss acc	K_xdom acc	K_pub acc	K_target acc
	IC-PQ-DIL-T32	K_loss acc	K_loss acc	K_pub acc	K_target acc	K_loss acc	K_pub acc	K_target acc	K_loss acc	K_xdom acc	K_pub acc	K_target acc	K_loss acc	K_xdom acc	K_pub acc	K_target acc
		T3/ S10	T3/ S11	T3/ S13	T3/ S14	T5/ S10	T5/ S13	T5/ S14	T7/ S10	T7/ S12	T7/ S13	T7/ S14	T8/ S10	T8/ S12	T8/ S13	T8/ S14

Fig. 10. Typed compromise matrix, separating ordinary recovery, bounded degradation, and compromise-assisted success; K_target rows are typed as compromise-assisted and excluded from positive resilience evidence.